

CISM CERTIFICATION EXAM SIMULATOR

Practice Exam 24

Domain IV - Incident Management

43 Questions	69 Minutes	Single Best Answer Format
-----------------	---------------	------------------------------

This publication contains original practice material designed for exam preparation. It does not reproduce confidential certification questions and is not affiliated with or endorsed by ISACA.

Instructions

- Allow approximately 69 minutes for this domain set.
- Select one best answer for every question.
- Record your selections before consulting the answer key.
- Review every explanation, including questions you answered correctly.

Questions

Question 1 (CISM6-108)

Scenario: A fisheries cooperative detects unauthorized commands to automated feeding systems overnight. Only the aquaculture director may suspend them, and the director is unreachable.

Which authority change would BEST remove this after-hours response bottleneck?

- A. Document risk-based suspension authority, limits, alternates, and escalation paths.
- B. Require feeding operations to continue until the vice president returns.
- C. Allow every employee to disable all aquaculture systems permanently.
- D. Transfer all feeding-system risk decisions to the equipment supplier.

Question 2 (CISM6-109)

Which organizational development MOST clearly requires an immediate plan review?

- A. A team changes its weekly meeting agenda.
- B. A dashboard receives a new color palette.
- C. An acquisition changes regulated services, reporting lines, suppliers, and escalation contacts.
- D. A low-impact office utility receives a routine update.

Question 3 (CISM6-110)

Scenario: A university and teaching hospital jointly operate a research platform, but their response plans assign conflicting commanders and isolation authority.

Which joint-response arrangement should be approved before further platform expansion?

- A. Separate command structures that exchange information only after closure.
- B. A rule that the first analyst to see an alert controls both companies.
- C. A joint response model defining accountable ownership, isolation authority, information flow, and escalation.
- D. Automatic public disclosure by either company without coordination.

Question 4 (CISM6-111)

Scenario: A regional services group reorganized operations and outsourced monitoring, yet its plan still assigns decisions to eliminated teams and omits new supplier interfaces.

Which remediation would provide the GREATEST improvement to the outdated response model?

- A. Create common governance, activation interfaces, decision authority, and tested handoffs across the plans.
- B. Let each plan owner retain incompatible terminology.
- C. Assign internal audit to lead every operational response.
- D. Add more malware indicators to the cyber plan.

Question 5 (CISM6-112)

Scenario: A rail operator identifies its timetable repository as critical but omits identity, licensing, synchronization, and communications dependencies.

What is the PRIMARY risk created by the incomplete dependency analysis?

- A. The incident log may contain too many entries.
- B. Recovery sequencing may fail because required supporting services are absent.
- C. The repository hardware may be overinsured.
- D. Every repository alert will necessarily become a disaster.

Question 6 (CISM6-113)

Scenario: A festival credential service has modest impact most of the year but becomes essential during a two-day admission period.

How should readiness requirements account for this concentrated period of impact?

- A. Set priority from the number of servers alone.
- B. Use only average annual transaction volume.
- C. Rate every credential event at maximum severity all year.
- D. Use time-sensitive priority, staffing, escalation, and recovery requirements for the peak period.

Question 7 (CISM6-114)

Scenario: A lender has a four-hour recovery time objective for loan applications but has not approved how much newly entered application data may be lost.

Which business recovery requirement remains to be defined?

- A. A recovery point objective based on acceptable loss of loan-application transactions.
- B. A target number of security alerts per day.
- C. A maximum duration for responder interviews.
- D. A standard attendance level for tabletop exercises.

Question 8 (CISM6-115)

Why must continuity arrangements be coordinated with incident response?

- A. To sustain prioritized activity while containment, recovery, and restoration proceed.
- B. To activate alternate sites for every security event.
- C. To replace containment with manual processing.
- D. To transfer investigation ownership to business staff.

Question 9 (CISM6-116)

Scenario: An emergency collaboration channel depends on the same mobile-device management service likely to be disabled during a device compromise.

Which alternate-communications improvement is MOST appropriate?

- A. Delay all continuity activity until the identity service returns.
- B. Accept the design because the workspace is externally hosted.
- C. Increase identity log retention without changing access.
- D. Develop and test an alternate access method that does not depend on the affected mobile-device management service.

Question 10 (CISM6-117)

Scenario: A pharmacy group's paper-order process supports 15 percent of demand, while the approved minimum during an outage is 55 percent.

What should management do about the demonstrated continuity-capacity gap?

- A. Approve the process because some results can be recorded.
- B. Redesign and exercise the process to meet the approved requirement or formally address the gap.
- C. Lower the minimum without clinical-owner approval.
- D. Wait for an outage to learn whether the shortfall matters.

Question 11 (CISM6-118)

Scenario: A membership organization plans to restore customer applications before the directory and certificate services required for authentication.

Which restoration sequence BEST respects the identified dependencies?

- A. Give all components the same recovery point objective.
- B. Restore the directory and certificate services before applications that depend on it.
- C. Recover the most visible application first regardless of prerequisites.
- D. Let each application team choose independently.

Question 12 (CISM6-119)

Scenario: A recovery exercise starts virtual machines but does not validate users, data, interfaces, or business transactions.

Which additional activity is needed to validate recovery capability?

- A. Only host startup times.
- B. A larger inventory of backup media.
- C. A review of office furniture at the alternate site.
- D. End-to-end validation of access, data, interfaces, transactions, dependencies, and recovery objectives.

Question 13 (CISM6-120)

Which description accurately differentiates RTO and RPO?

- A. RTO measures lost data, while RPO measures staff availability.
- B. RTO addresses acceptable restoration time, while RPO addresses acceptable data loss measured in time.
- C. Both terms describe the maximum length of an investigation.
- D. Both terms are always identical to supplier service levels.

Question 14 (CISM6-121)

Scenario: A software company ranks incidents by device count, placing suspected theft of one code-signing key below adware on many visitor kiosks.

Which revision would BEST improve the company's severity model?

- A. Base severity only on hardware replacement cost.
- B. Assign maximum severity to every signing-key alert.
- C. Let each responder choose a rating without criteria.
- D. Include information sensitivity, software-trust impact, trust, scope, urgency, and applicable obligations.

Question 15 (CISM6-122)

Scenario: A leisure company tells responders to escalate events that look important, producing inconsistent legal, safety, and executive involvement.

Which escalation approach should replace the subjective instruction?

- A. Escalation only after financial loss is final.
- B. Escalation whenever any user requests it.
- C. Documented thresholds based on impact, data, scope, urgency, safety, and obligations.
- D. Board escalation for every blocked alert.

Question 16 (CISM6-123)

Scenario: A streaming service gives outages, account abuse, content manipulation, and privacy events the same category and response route.

Which classification design would BEST improve specialist routing?

- A. Separate category and severity, then map their combinations to owners, actions, authority, and escalation.
- B. Create one severity for every content title.
- C. Use estimated repair hours as the sole field.
- D. Retain one label and add more email recipients.

Question 17 (CISM6-124)

Scenario: A public-works exercise reveals no alternate commander, regulatory liaison, or executive briefing owner, although technical response succeeds.

Which readiness investment should be prioritized after the exercise?

- A. Teach board members to analyze malware.
- B. Remove customs and board injects from later tests.
- C. Map competencies to roles, assign trained personnel and alternates, and retest the gaps.
- D. Ask a contractor to make all corporate decisions.

Question 18 (CISM6-125)

Scenario: A finance company repeats an identical announced tabletop, and participants now recite prepared decisions without discussing tradeoffs.

How should the tabletop program be changed to test real judgment?

- A. Use varied scenarios and injects tied to decision, coordination, communication, and recovery objectives.
- B. Stop documenting results because performance is consistent.
- C. Score only the speed of alert recognition.
- D. Exclude business leaders to shorten the session.

Question 19 (CISM6-126)

Which exercise format BEST evaluates executive coordination without affecting live systems?

- A. An unannounced shutdown of live systems.
- B. A facilitated tabletop with progressive business and stakeholder injects.
- C. A routine vulnerability scan.
- D. A count of employees who downloaded the plan.

Question 20 (CISM6-127)

Scenario: A simulation report identifies delayed supplier escalation but assigns no owner, deadline, evidence requirement, or retest.

Which follow-up mechanism should be established before closing the simulation?

- A. Delete difficult observations before leadership review.
- B. Create prioritized corrective actions with owners, dates, validation evidence, and retesting.
- C. Use attendance as the only success measure.
- D. Approve the plan because the simulation ended.

Question 21 (CISM6-128)

Which determination is the central purpose of initial triage?

- A. An initial determination of incident status, impact, priority, ownership, and routing.
- B. A completed root-cause analysis.
- C. A final external notification package.
- D. A permanent redesign of affected systems.

Question 22 (CISM6-129)

Scenario: A building operator receives reports of blocked scans and unexplained changes to fire-suppression configuration values.

Which report should receive FIRST assessment?

- A. The scans because they contain more events.
- B. The fire-suppression changes because possible integrity and patient-safety impact require urgent triage.
- C. Neither until malicious intent is proven.
- D. Both after the next scheduled meeting.

Question 23 (CISM6-130)

Scenario: Community volunteers report suspicious portal activity to individual coordinators, and reports are frequently missed outside business hours.

Which intake improvement would MOST effectively address the reporting gap?

- A. Require volunteers to prove compromise before reporting.
- B. Ask coordinators to conduct forensic analysis.
- C. Ignore reports from volunteers below a participation threshold.
- D. Provide a monitored supplier-reporting channel with acknowledgment, intake guidance, and escalation.

Question 24 (CISM6-131)

Scenario: A robotic packaging system begins moving equipment into occupied work areas. Emergency isolation may overwrite volatile diagnostic data.

Which immediate response BEST balances safety and evidence needs?

- A. Continue unsafe production until all data is collected.
- B. Place the process in a safe state using authorized procedures, document actions, and preserve feasible evidence.
- C. Erase the controller without recording the action.
- D. Wait for the equipment vendor to decide whether safety matters.

Question 25 (CISM6-132)

Scenario: A privileged administrator suspected of concealing unauthorized activity is proposed as the sole investigator because of specialized knowledge.

Which investigation-governance decision is MOST appropriate?

- A. Assign independent investigators, control access as authorized, and coordinate with legal and human resources.
- B. Accept a verbal summary from the administrator.
- C. Publicly name the administrator before validation.
- D. Stop the inquiry unless the administrator agrees.

Question 26 (CISM6-133)

Scenario: Badge-access exports relevant to warehouse theft are copied to personal drives without source records, hashes, custodians, or transfer logs.

What is the principal evidentiary weakness in this handling process?

- A. The records necessarily identify the wrong employee.
- B. Evidence integrity and provenance may be challenged because custody was not maintained.
- C. The incident automatically becomes a disaster.
- D. Every recovery objective must be shortened.

Question 27 (CISM6-134)

Scenario: A multinational organization proposes collecting complete call recordings across several countries after suspected insider disclosure; local privacy rules differ.

Which coordination step should precede collection of the recordings?

- A. Coordinate legal, privacy, human resources, and investigators on lawful, proportionate collection and preservation.
- B. Let local supervisors decide legal authority individually.
- C. Notify the suspected individuals publicly.
- D. Collect every recording immediately under one global rule.

Question 28 (CISM6-135)

Which consideration should drive selection of a proportionate containment strategy?

- A. The personal preference of the first analyst.
- B. The action used in the previous incident.
- C. The balance among continuing harm, safety, business impact, evidence, authority, and recovery options.
- D. The length of the technical procedure.

Question 29 (CISM6-136)

Scenario: A platform confirms abuse of one reseller credential. Disabling every reseller connection would interrupt service for thousands of unaffected users.

Which containment decision BEST limits both harm and collateral disruption?

- A. Leave the key active until service delivery closes.
- B. Revoke the affected key, isolate the reseller connection, preserve records, and monitor for related abuse.
- C. Disable the entire platform without assessing narrower options.
- D. Delete API logs before isolation.

Question 30 (CISM6-137)

Scenario: An airport cannot replace unsupported passenger-information displays for eight weeks; segmentation reduces exposure but increases support effort.

Which long-term containment approach is MOST appropriate?

- A. Implement tested, monitored, business-approved restrictions with an expiration date and tracked replacement.
- B. Accept the exposure indefinitely without approval.
- C. Restore unrestricted connectivity to improve speed.
- D. Disconnect every display without considering airport operations.

Question 31 (CISM6-138)

Scenario: Online posts claim a foundation exposed all beneficiary records. Responders have confirmed an application outage but no data disclosure.

Which early public communication is BEST supported by the known facts?

- A. Confirm the rumored loss to appear decisive.
- B. Publish investigators' competing theories.
- C. Remain silent until every corrective action is complete.
- D. Issue an approved holding statement describing verified impact, response activity, and update channels.

Question 32 (CISM6-139)

Scenario: A managed-services firm discovers possible customer-data exposure across several contractual and regulatory environments while scope remains under investigation.

What should the manager initiate FIRST regarding external notification?

- A. A delay until final root-cause analysis.
- B. One universal deadline copied from an unrelated rule.
- C. A statement that every customer suffered identity theft.
- D. A coordinated legal, privacy, contract, insurance, and business assessment of verified facts and applicable duties.

Question 33 (CISM6-140)

Scenario: During a cloud-integrity incident, executives receive raw alerts while engineers receive only a reputation estimate.

Which reporting design would make updates useful to both audiences?

- A. Create audience-specific updates from one verified incident record, aligned with decision needs and cadence.
- B. Send identical raw detail to every recipient.
- C. Allow teams to publish independent estimates.
- D. Stop scheduled updates and answer only questions.

Question 34 (CISM6-141)

Scenario: A cyber incident disrupts regional emergency-pharmacy dispensing during severe weather, but routine technical calls exclude crisis leadership.

Which escalation action is required at this point?

- A. Wait for final technical root cause.
- B. Activate crisis coordination for operational, executive, government, partner, and public communication needs.
- C. Allow individual analysts to brief the public.
- D. Close the incident because pharmacy operators own service delivery.

Question 35 (CISM6-142)

Scenario: A cloud application is rebuilt after access abuse, but investigators find active unauthorized refresh tokens and a compromised recovery account.

What must be completed before normal access is restored?

- A. Declare eradication complete because the known malicious component is gone.
- B. Restore access and address sessions later.
- C. Revoke unauthorized sessions, secure recovery paths, remediate the weakness, and validate removal of persistence.
- D. Close the incident and treat the recovery-account issue as routine support.

Question 36 (CISM6-143)

What is the PRIMARY objective of recovery validation?

- A. To transfer acceptance authority to a vendor.
- B. To prove no future incident can occur.
- C. To remove the need for enhanced monitoring.
- D. To confirm functionality, integrity, security, dependencies, and agreed business outcomes before normal use.

Question 37 (CISM6-144)

Scenario: An inventory platform is available after unauthorized record changes, but stock totals do not reconcile with signed warehouse counts.

Which return-to-normal decision is BEST supported by the current evidence?

- A. Resume inventory processing because infrastructure tests pass.
- B. Let the hosting supplier accept the discrepancy.
- C. Maintain restrictions until reconciliation and recovery criteria are satisfied and the designated business owner accepts service.
- D. Declare success solely because the RTO was reached.

Question 38 (CISM6-145)

Scenario: A service is restored after credential theft; access paths were closed and validation passed, but recurrence risk remains elevated.

Which operational step should follow successful restoration?

- A. Disable logging to improve performance.
- B. Immediately delete all incident indicators.
- C. Restore service gradually with enhanced recurrence monitoring
- D. Keep the service offline until all enterprise risk disappears.

Question 39 (CISM6-146)

Scenario: A multimodal support assistant disclosed internal procedures after crafted image inputs; prior assessments and exercises covered text only.

Which post-incident improvement package BEST addresses the newly observed channel?

- A. Document the event but retain existing assumptions.
- B. Permanently ban all multimodal service without business analysis.
- C. Rely only on employee reminders.
- D. Reassess the risk, revise response criteria and safeguards, train relevant roles, and test image-input scenarios.

Question 40 (CISM6-147)

Scenario: After accidental document publication, a director wants the review to identify only the employee who approved the final workflow step.

How should the information security manager redirect the review?

- A. Exclude process owners.
- B. Begin by publicly naming the employee.
- C. Examine design, approvals, workload, training, oversight, and contributing factors while using proper personnel channels.
- D. Cancel the review because human error was involved.

Question 41 (CISM6-148)

Scenario: Backups repeatedly fail because job ownership is undefined, alerts route to a departed employee, and no escalation exists.

Which finding BEST describes the systemic root cause?

- A. Backup-job governance failed to assign ownership, monitor failures, and escalate missed action.
- B. Business users did not receive recent backup confirmations.
- C. Responders restarted several backup agents.
- D. The service desk received questions about restore readiness.

Question 42 (CISM6-149)

Scenario: Six months after a partner incident, review recommendations remain in notes without owners, dates, evidence, or exception approval.

Which corrective-action mechanism should now be implemented?

- A. A governed corrective-action register with ownership, priority, dates, validation, escalation, and formal risk acceptance.
- B. Automatic closure after a fixed number of months.
- C. Verbal completion claims without evidence.
- D. Progress review limited to original responders.

Question 43 (CISM6-150)

Scenario: A transport cooperative reports only incident totals and cannot show trends in impact, response speed, recurrence, recovery, or overdue actions.

Which balanced metric set would provide the MOST useful management view?

- A. Only alerts generated per tool.
- B. Only responder labor hours.
- C. Impact, response, recurrence, recovery, and remediation trends
- D. Only incidents marked closed.

Answer Key

Domain IV - Incident Management

1 A	2 C	3 C	4 A	5 B
6 D	7 A	8 A	9 D	10 B
11 B	12 D	13 B	14 D	15 C
16 A	17 C	18 A	19 B	20 B
21 A	22 B	23 D	24 B	25 D
26 B	27 A	28 C	29 B	30 A
31 D	32 D	33 A	34 B	35 C
36 D	37 C	38 C	39 D	40 C
41 A	42 C	43 C		

Detailed Explanations

Question 1 (CISM6-108)

Correct answer: A - Document risk-based suspension authority, limits, alternates, and escalation paths.

For this situation, bounded delegation enables timely containment while preserving accountability. Waiting permits potential harm, unrestricted authority is excessive, and a vendor cannot assume the cooperative's final risk decision.

Question 2 (CISM6-109)

Correct answer: C - An acquisition changes regulated services, reporting lines, suppliers, and escalation contacts.

For this situation, an acquisition can invalidate scope, ownership, dependencies, contacts, and obligations. Meeting formats, presentation colors, and routine low-impact updates do not materially alter response governance.

Question 3 (CISM6-110)

Correct answer: C - A joint response model defining accountable ownership, isolation authority, information flow, and escalation.

For this situation, a joint model resolves authority and coordination before an incident occurs. Separate command delays decisions, initial detection does not confer enterprise authority, and uncoordinated disclosure can conflict with verified facts and obligations.

Question 4 (CISM6-111)

Correct answer: A - Create common governance, activation interfaces, decision authority, and tested handoffs across the plans.

For this situation, common governance and tested interfaces prevent conflicting activation and ownership. More indicators do not resolve coordination, incompatible terms preserve ambiguity, and internal audit should not assume operational command.

Question 5 (CISM6-112)

Correct answer: B - Recovery sequencing may fail because required supporting services are absent.

For this situation, a critical service cannot be restored effectively without its prerequisites. Log volume and insurance are unrelated, and missing dependencies do not automatically make every alert a disaster.

Question 6 (CISM6-113)

Correct answer: D - Use time-sensitive priority, staffing, escalation, and recovery requirements for the peak period.

For this situation, time-sensitive requirements reflect the period of greatest business harm. Annual averages conceal peak exposure, permanent maximum severity wastes resources, and server count is not a business-impact measure.

Question 7 (CISM6-114)

Correct answer: A - A recovery point objective based on acceptable loss of loan-application transactions.

For this situation, the RPO defines acceptable data loss and complements the time objective. Alert volume, interview duration, and exercise attendance do not establish the permissible rollback of loan-application data.

Question 8 (CISM6-115)

Correct answer: A - To sustain prioritized activity while containment, recovery, and restoration proceed.

For this situation, continuity sustains essential business activity during disruption while incident teams address the cause and recovery. It does not own investigations, activate for every event, or replace containment decisions.

Question 9 (CISM6-116)

Correct answer: D - Develop and test an alternate access method that does not depend on the affected mobile-device management service.

For this situation, an effective workaround must avoid the likely failed dependency and be tested. External hosting does not remove device-management reliance, more logs do not restore access, and delay defeats continuity objectives.

Question 10 (CISM6-117)

Correct answer: B - Redesign and exercise the process to meet the approved requirement or formally address the gap.

For this situation, the known gap should be corrected and tested or explicitly accepted by accountable owners. Partial capacity, an unauthorized requirement change, or waiting for a real incident leaves patient-service risk unmanaged.

Question 11 (CISM6-118)

Correct answer: B - Restore the directory and certificate services before applications that depend on it.

For this situation, the identity foundation is a prerequisite and must be restored before dependent applications can operate securely. Equal RPOs do not solve order, visibility does not override dependency, and independent sequencing creates conflicts.

Question 12 (CISM6-119)

Correct answer: D - End-to-end validation of access, data, interfaces, transactions, dependencies, and recovery objectives.

For this situation, server startup does not prove business usability. End-to-end testing validates the complete recovered service, while host timing, media inventory, and furniture do not demonstrate operational recovery.

Question 13 (CISM6-120)

Correct answer: B - RTO addresses acceptable restoration time, while RPO addresses acceptable data loss measured in time.

For this situation, rTO concerns how quickly service must return; RPO concerns how much data loss is acceptable. Neither measures staffing or investigation duration, and supplier targets need not equal business objectives.

Question 14 (CISM6-121)

Correct answer: D - Include information sensitivity, software-trust impact, trust, scope, urgency, and applicable obligations.

For this situation, multidimensional criteria capture the potential software-trust impact of one critical signing key. Hardware cost and unstructured judgment are inadequate, while automatic maximum ratings ignore verified context.

Question 15 (CISM6-122)

Correct answer: C - Documented thresholds based on impact, data, scope, urgency, safety, and obligations.

For this situation, objective thresholds enable consistent, timely routing to appropriate stakeholders. Final loss is too late, user requests alone are insufficient, and board involvement for every alert creates noise.

Question 16 (CISM6-123)

Correct answer: A - Separate category and severity, then map their combinations to owners, actions, authority, and escalation.

For this situation, category identifies incident nature and severity expresses impact and urgency; mapping both improves routing. Title-level severities are unwieldy, repair time is incomplete, and wider email distribution does not resolve ambiguity.

Question 17 (CISM6-124)

Correct answer: C - Map competencies to roles, assign trained personnel and alternates, and retest the gaps.

For this situation, role mapping, training, alternates, and retesting address the actual readiness weaknesses. Technical board training, narrower exercises, and outsourced corporate authority do not.

Question 18 (CISM6-125)

Correct answer: A - Use varied scenarios and injects tied to decision, coordination, communication, and recovery objectives.

For this situation, varied objective-driven exercises test judgment rather than memory. Removing documentation, relying on one technical metric, or excluding leaders weakens assurance over management response.

Question 19 (CISM6-126)

Correct answer: B - A facilitated tabletop with progressive business and stakeholder injects.

For this situation, a facilitated tabletop safely tests leadership decisions and cross-functional coordination. A live shutdown creates risk, a scan tests controls, and download counts do not demonstrate capability.

Question 20 (CISM6-127)

Correct answer: B - Create prioritized corrective actions with owners, dates, validation evidence, and retesting.

For this situation, accountable actions and retesting turn findings into measurable improvement. Suppression, attendance alone, and exercise completion do not show that identified gaps are resolved.

Question 21 (CISM6-128)

Correct answer: A - An initial determination of incident status, impact, priority, ownership, and routing.

For this situation, triage establishes whether reported activity is an incident and how it should initially be handled. Root cause, notification, and redesign require later facts and authorization.

Question 22 (CISM6-129)

Correct answer: B - The fire-suppression changes because possible integrity and patient-safety impact require urgent triage.

For this situation, potentially altered fire-suppression settings create immediate occupant-safety risk and outweigh blocked scans. Event volume alone is not impact, and waiting for a meeting or proven intent may allow harm.

Question 23 (CISM6-130)

Correct answer: D - Provide a monitored supplier-reporting channel with acknowledgment, intake guidance, and escalation.

For this situation, a monitored channel supports early, consistent reporting and triage. Proof requirements and coordinator investigations delay response, while volunteer role does not determine incident relevance.

Question 24 (CISM6-131)

Correct answer: B - Place the process in a safe state using authorized procedures, document actions, and preserve feasible evidence.

For this situation, safety and stabilization take priority, while documentation and feasible evidence collection should continue. Continuing unsafe operation is unacceptable, undocumented erasure harms investigation, and the organization retains safety authority.

Question 25 (CISM6-132)

Correct answer: D - Stop the inquiry unless the administrator agrees.

For this situation, independent oversight protects evidence and due process while appropriate specialists coordinate personnel and legal issues. Self-investigation creates conflict, consent is not the governing condition, and public attribution is premature.

Question 26 (CISM6-133)

Correct answer: B - Evidence integrity and provenance may be challenged because custody was not maintained.

For this situation, missing integrity and handling records weaken evidentiary reliability. They do not predetermine attribution, define a disaster, or justify unrelated recovery changes.

Question 27 (CISM6-134)

Correct answer: A - Coordinate legal, privacy, human resources, and investigators on lawful, proportionate collection and preservation.

For this situation, cross-border collection requires specialist coordination to establish authority, proportionality, handling, and preservation. A universal rule may be unlawful, supervisors are not legal decision makers, and public identification is premature.

Question 28 (CISM6-135)

Correct answer: C - The balance among continuing harm, safety, business impact, evidence, authority, and recovery options.

For this situation, containment is a risk-based decision balancing harm reduction with operational, evidentiary, safety, authority, and recovery needs. Preference, precedent, and document length alone are insufficient.

Question 29 (CISM6-136)

Correct answer: B - Revoke the affected key, isolate the reseller connection, preserve records, and monitor for related abuse.

For this situation, targeted revocation stops the confirmed path while limiting business impact and preserving evidence. Delay permits harm, full shutdown may be disproportionate, and log deletion impairs investigation.

Question 30 (CISM6-137)

Correct answer: A - Implement tested, monitored, business-approved restrictions with an expiration date and tracked replacement.

For this situation, time-bounded compensating measures balance reduced exposure with operations until remediation. Convenience does not justify risk, indefinite acceptance lacks accountability, and wholesale disconnection may create safety issues.

Question 31 (CISM6-138)

Correct answer: D - Issue an approved holding statement describing verified impact, response activity, and update channels.

For this situation, a factual holding statement addresses stakeholder needs without spreading unsupported claims. Confirming rumors or theories is premature, while prolonged silence can worsen confusion.

Question 32 (CISM6-139)

Correct answer: D - A coordinated legal, privacy, contract, insurance, and business assessment of verified facts and applicable duties.

For this situation, notification assessment should start promptly using verified facts and applicable obligations. A universal deadline may be wrong, asserted harm may be unsupported, and full root cause is not required to begin analysis.

Question 33 (CISM6-140)

Correct answer: A - Create audience-specific updates from one verified incident record, aligned with decision needs and cadence.

For this situation, a common verified source maintains consistency while tailored reporting supports each role. Uniform detail creates noise, independent estimates conflict, and purely reactive communication weakens oversight.

Question 34 (CISM6-141)

Correct answer: B - Activate crisis coordination for operational, executive, government, partner, and public communication needs.

For this situation, widespread essential-service impact requires enterprise crisis coordination while technical response continues. Waiting delays action, individual briefings create inconsistency, and operational ownership does not end the incident.

Question 35 (CISM6-142)

Correct answer: C - Revoke unauthorized sessions, secure recovery paths, remediate the weakness, and validate removal of persistence.

For this situation, eradication must address all known access paths and enabling weaknesses. Removing one artifact is incomplete, delay preserves unauthorized access, and routine-ticket treatment would close the incident prematurely.

Question 36 (CISM6-143)

Correct answer: D - To confirm functionality, integrity, security, dependencies, and agreed business outcomes before normal use.

For this situation, validation establishes that the service is trustworthy and fit for business use. It cannot prove zero future risk, replace monitoring, or transfer organizational acceptance.

Question 37 (CISM6-144)

Correct answer: C - Maintain restrictions until reconciliation and recovery criteria are satisfied and the designated business owner accepts service.

For this situation, availability alone does not prove integrity. Restrictions should remain until validation and business acceptance; suppliers cannot accept organizational risk, and reaching the RTO does not override failed reconciliation.

Question 38 (CISM6-145)

Correct answer: C - Restore service gradually with enhanced recurrence monitoring

For this situation, controlled return with enhanced monitoring provides assurance during stabilization. Disabling visibility or deleting indicators is premature, while waiting for elimination of all risk is impractical.

Question 39 (CISM6-146)

Correct answer: D - Reassess the risk, revise response criteria and safeguards, train relevant roles, and test image-input scenarios.

For this situation, the review should update risk assumptions, safeguards, procedures, training, and exercises based on observed behavior. No change or reminders alone are incomplete, while a blanket ban may be disproportionate.

Question 40 (CISM6-147)

Correct answer: C - Examine design, approvals, workload, training, oversight, and contributing factors while using proper personnel channels.

For this situation, a systemic review identifies sustainable improvements and supports candor. Excluding owners, public blame, or cancellation leaves organizational weaknesses unresolved.

Question 41 (CISM6-148)

Correct answer: A - Backup-job governance failed to assign ownership, monitor failures, and escalate missed action.

For this situation, the failed ownership, monitoring, and escalation process explains the recurring backup failures. Missing confirmations and questions are symptoms, while restarting agents is a response action rather than the systemic root cause.

Question 42 (CISM6-149)

Correct answer: C - Verbal completion claims without evidence.

For this situation, a governed register turns lessons into accountable and verifiable improvement and exposes residual-risk decisions. Time, unsupported claims, and narrow review do not demonstrate completion.

Question 43 (CISM6-150)

Correct answer: C - Impact, response, recurrence, recovery, and remediation trends

For this situation, balanced measures connect operations to business consequence, timeliness, repeated causes, recovery, and improvement. Alert, labor, or closure counts alone can hide deteriorating risk.